VULNERABILITY ASSESSMENT & PENETRATION TESTING REPORT

Session S07 | Target: Metasploitable 2 | Toolchain: Kali Linux, Nmap, Metasploit Framework, Greenbone GVM/OpenVAS

Student: Muhammad Latif

Cohort: 02-Weekend-ISB

Target host: Metasploitable 2 (intentionally vulnerable training VM), 192.168.100.114/24

Assessing host: Kali Linux Rolling, 192.168.100.113/24

Engagement type: Grey-box internal security assessment

Instructor: Waseem Abbas Khan, Senior Cybersecurity Specialist

Programme: Atomcamp & Pakistan Software Export Board (PSEB)

Repository: https://github.com/MuhammadLateef/digital-forensic-cyber-security-pseb-bootcamp/tree/main/s07-report

LEGAL & ETHICAL NOTICE

All activity described in this report was carried out against an isolated, host-only laboratory network built for this course, under explicit written authorization from the instructor and the programme. No production system, third-party asset, or system outside the authorized scope was accessed or tested at any point. Testing a system without prior, explicit authorization is a criminal offence under Pakistan's Prevention of Electronic Crimes Act (PECA) 2016, and under comparable legislation in other jurisdictions.

1. Executive Summary

This report documents an authorized grey-box Vulnerability Assessment and Penetration Testing (VA/PT) engagement against a single target host, 192.168.100.114, inside an isolated host-only laboratory network. The engagement had three goals:

1. Map the exposed attack surface and match it against known vulnerability signatures using Greenbone Vulnerability Management (GVM/OpenVAS).
2. Independently confirm which of those weaknesses could actually be exploited, through controlled, manual proof-of-concept testing with the Metasploit Framework and native Linux tools.
3. Turn both result sets into a short, prioritized list of fixes.

Key Metrics

Metric	Result	What it means
Findings fully validated with proof of concept	4	Four independent attack vectors were confirmed, not just theorized.
Critical-severity findings (CVSS ≥ 9.0)	3 of 4	Unauthenticated remote code execution was achievable through each.
High-severity findings	1 of 4	Required a known default password, not a software flaw.
Independent root shells obtained	4 separate paths	vsftpd backdoor, Samba RCE, raw bind shell, SSH + sudo
Sensitive data exposure confirmed	Yes	/etc/shadow password-hash file was read in full
Automated GVM/OpenVAS scan	Configured, feed sync in progress	See Section 6 — no completed scan report is included in this evidence set

Primary Business Impact

An attacker on the same network as this host does not need a username, a password, or any special preparation. At least three separate, unauthenticated paths lead straight to full root access: a known backdoor in the FTP service, a raw root shell left listening on a spare port, and a command-injection flaw in the file-sharing service. From any one of these, the attacker can read every password hash on the machine and set up ways to keep their access, all without tripping any login check or logging control.

Scope and Limitations

This engagement covered only the single host 192.168.100.114, on an isolated host-only network segment, over a fixed two-day testing window. Testing was grey-box: the assessor was given the target scope and general environment context, but no pre-shared credentials. Readers of this report should keep the following limitations in mind:

4. The GVM/OpenVAS scan is reported at the tool's default 70% Quality of Detection (QoD) threshold, so lower-confidence results are excluded from the severity counts.
5. Only four findings were taken through to full proof-of-concept exploitation. Other results an automated scanner might flag were not manually confirmed.

6. At the time the evidence for this report was captured, the GVM NVT (Network Vulnerability Test) feed had reached a Current status, but the SCAP, CERT and GVMD_DATA feeds were still updating, and no completed scan task or report is included in this evidence set. Any automated-scan findings should be treated as pending, not confirmed, until that scan is completed and reviewed.

2. Methodology

The engagement followed a standard four-phase penetration-testing approach, aligned with PTES (the Penetration Testing Execution Standard) and OWASP testing guidance, scaled down for a single-host lab:

7. **Reconnaissance and network-isolation check.** Confirm the target is reachable, and confirm the test network has no route to production or external networks, before any intrusive activity begins.
8. **Active enumeration.** Full TCP port, service and OS fingerprinting with Nmap, to map the attack surface.
9. **Vulnerability analysis.** Automated matching of service banners and versions against known-vulnerability signatures using Greenbone GVM/OpenVAS, cross-checked against manual research (NVD/CVE, Exploit-DB, the Metasploit module database).
10. **Exploitation and post-exploitation.** Controlled, in-scope proof-of-concept exploitation of confirmed vulnerabilities using Metasploit and native OS tools, followed by a brief, reversible demonstration of impact.

Severity is scored throughout this report using CVSS v3.1 base metrics, and weaknesses are classified against MITRE CWE identifiers. All commands, tool output and screenshots were captured live during the stated engagement window.

3. Host and Network Isolation Verification

Before any intrusive testing began, the lab network was checked to confirm it was a closed, host-only segment with no route to production networks or the internet — a standard safety control before any offensive-security exercise.

```
ip -br addr show
target=192.168.100.114
ping -c 2 $target
ping -c 2 -W 1 8.8.8.8
```

The assessing host (192.168.100.113) reached the target (192.168.100.114) over the local segment with no packet loss (round-trip time around 1.3–1.5 ms). An outbound probe to a public DNS resolver (8.8.8.8) returned only one reply out of two (50% loss), which suggests the lab segment has little or no usable route to the internet. An earlier attempt in the same session used the wrong target address and a shell-syntax mistake, both visible in Figure 1 and corrected before the final result.

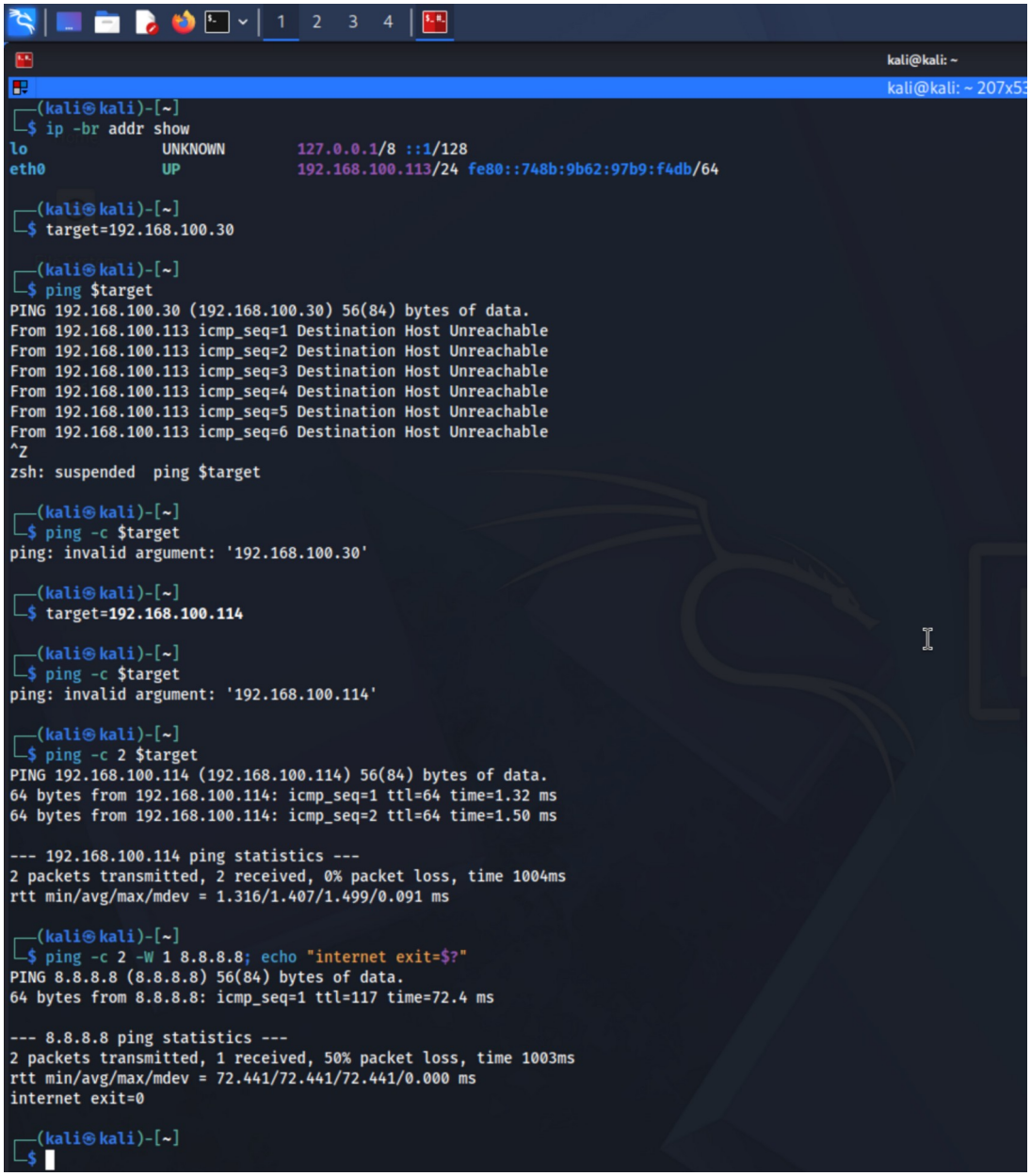


Figure 1: *Terminal session showing the corrected ping test to the target (0% packet loss) and the limited response from the external probe to 8.8.8.8.*

Interpretation

This step is a safety check, not a finding: it shows that every exploitation step later in this report happened inside an authorized lab boundary, and that the lab segment has, at most, very limited reach beyond itself.

4. Active Service Enumeration and Attack Surface Mapping

A full TCP scan with service and version detection, default NSE scripts, and OS fingerprinting was run against the target:

```
sudo nmap -sV -sC -O -T4 192.168.100.114 -oN nmap_report_services.txt
```

The scan found 23 open TCP ports out of 1,000 scanned, several of which are, by themselves, enough to fully compromise the host. The table below summarizes the results that matter most to this assessment; the full scan output is shown in Figures 2 to 4.

Port	Service	Version	Why it matters
21/tcp	ftp	vsftpd 2.3.4	Anonymous login allowed; known backdoored build (Finding 1)
22/tcp	ssh	OpenSSH 4.7p1 (Debian 8ubuntu1)	Reachable with a known default credential pair (Finding 2)
23/tcp	telnet	Linux telnetd	Unencrypted remote login
25/tcp	smtp	Postfix smtpd	SSLv2 supported with weak ciphers; certificate expired since 2010
53/tcp	domain	ISC BIND 9.4.2	Version disclosed in banner
80/tcp	http	Apache httpd 2.2.8	Outdated web server version
111/tcp	rpcbind	RPC #100000	Exposes NFS/mount services
139/445/tcp	netbios-ssn	Samba smbd 3.0.20-Debian	SMB signing disabled; vulnerable to CVE-2007-2447 (Finding 4)
512-514/tcp	exec / login / shell	rsh-family services	Legacy remote-login services, no encryption
1099/tcp	java-rmi	GNU Classpath grmiregistry	Exposed RMI registry
1524/tcp	bindshell	“Metasploitable root shell” (Nmap fingerprint)	Unauthenticated root shell (Finding 3)
2121/tcp	ftp	ProFTPD 1.3.1	Second FTP service
3306/tcp	mysql	MySQL 5.0.51a	Reachable database service
5432/tcp	postgresql	PostgreSQL 8.3.0 - 8.3.7	Reachable database service
5900/tcp	vnc	VNC protocol 3.3	Legacy remote-desktop protocol
6667/tcp	irc	UnrealIRCd	Historically linked to a separate backdoor (not tested here)
8009/8180/tcp	ajp13 / http	Apache Jserv / Tomcat 5.5	Outdated application server

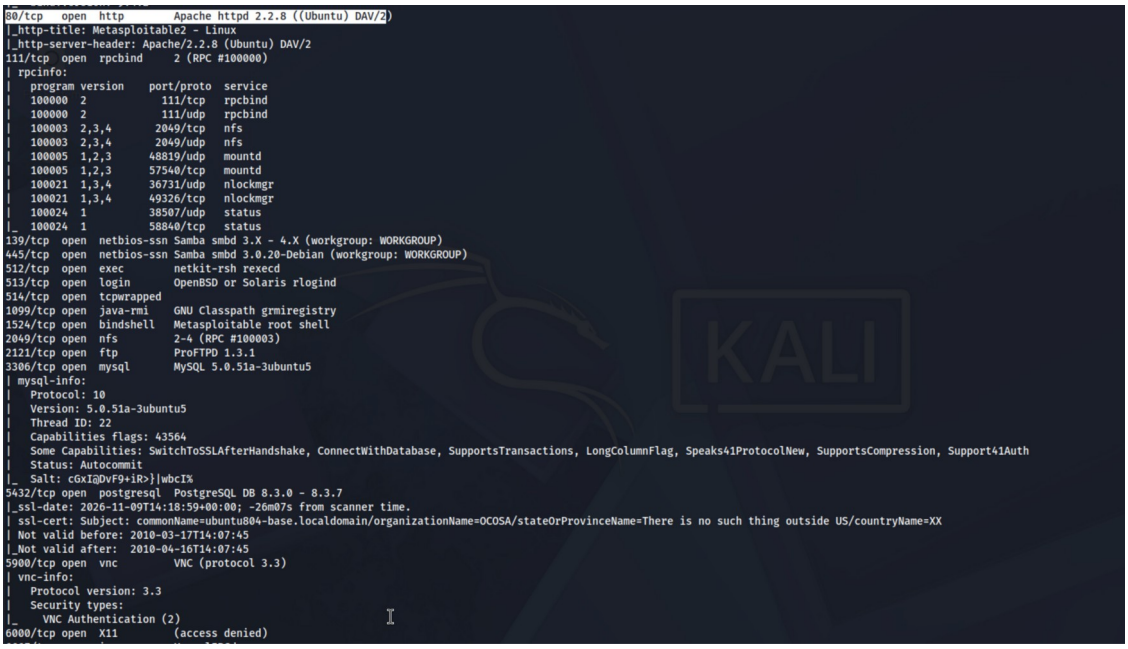


```
┌──(kali㉿kali)-[~]
└─$ mkdir -p ~/Lab3_Practical/logs

┌──(kali㉿kali)-[~]
└─$ cd ~/Lab3_Practical/logs

┌──(kali㉿kali)-[~/Lab3_Practical/logs]
└─$ sudo nmap -sV -sC -O -T4 192.168.100.114 -oN nmap_report_services.txt
[sudo] password for kali:
Starting Nmap 7.99 ( https://nmap.org ) at 2026-11-09 19:44 +0500
Nmap scan report for 192.168.100.114
Host is up (0.0011s latency).
Not shown: 977 closed tcp ports (reset)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 2.3.4
|_ftp-anon: Anonymous FTP login allowed (FTP code 230)
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to 192.168.100.113
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      vsFTPd 2.3.4 - secure, fast, stable
|_End of status
22/tcp   open  ssh         OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
| ssh-hostkey:
|   1024 60:0f:cf:e1:c0:5f:6a:74:d6:90:24:fa:c4:d5:6c:cd (DSA)
|_  2048 56:56:24:0f:21:1d:de:a7:2b:ae:61:b1:24:3d:e8:f3 (RSA)
23/tcp   open  telnet      Linux telnetd
25/tcp   open  smtp        Postfix smtpd
|_ssl-date: 2026-11-09T14:18:59+00:00; -26m07s from scanner time.
| sslv2:
|   SSLv2 supported
|   ciphers:
|     SSL2_RC2_128_CBC_WITH_MD5
|     SSL2_RC4_128_WITH_MD5
|     SSL2_DES_192_EDE3_CBC_WITH_MD5
|     SSL2_DES_64_CBC_WITH_MD5
|     SSL2_RC2_128_CBC_EXPORT40_WITH_MD5
|_    SSL2_RC4_128_EXPORT40_WITH_MD5
|_smtp-commands: metasploitable.localdomain, PIPELINING, SIZE 10240000, VRFY, ETRN, STARTTLS, ENHANCEDSTATUSCODES, 8BITMIME, DSN
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
53/tcp   open  domain      ISC BIND 9.4.2
| dns-nsid:
|_  bind.version: 9.4.2
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
```

Figure 2: *Nmap scan output, part 1 of 3: ports 21-53, including the vsftpd and SSL/SSLv2 details.*



```
80/tcp   open  http        Apache httpd 2.2.8 ((Ubuntu) DAV/2)
|_http-title: Metasploitable2 - Linux
|_http-server-header: Apache/2.2.8 (Ubuntu) DAV/2
111/tcp  open  rpcbind     2 (RPC #100000)
| rpcinfo:
|   program version    port/proto  service
|   100000  2            111/tcp   rpcbind
|   100000  2            111/udp   rpcbind
|   100003  2,3,4       2049/tcp   nfs
|   100003  2,3,4       2049/udp   nfs
|   100005  1,2,3      48819/udp   mountd
|   100005  1,2,3      57540/tcp   mountd
|   100021  1,3,4      36731/udp   nlockmgr
|   100021  1,3,4      49326/tcp   nlockmgr
|   100024  1          38507/udp   status
|_  100024  1          58840/tcp   status
139/tcp  open  netbios-ssn Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp  open  netbios-ssn Samba smbd 3.0.20-Debian (workgroup: WORKGROUP)
512/tcp  open  exec        netkit-rsh rexecd
513/tcp  open  login       OpenBSD or Solaris rlogind
514/tcp  open  tcpwrapped
1099/tcp open  java-rmi    GNU Classpath grmiregistry
1524/tcp open  bindshell   Metasploitable root shell
2049/tcp open  nfs         2-4 (RPC #100003)
2121/tcp open  ftp         ProFTPD 1.3.1
3306/tcp open  mysql       MySQL 5.0.51a-3ubuntu5
| mysql-info:
|   Protocol: 10
|   Version: 5.0.51a-3ubuntu5
|   Thread ID: 22
|   Capabilities flags: 43564
|   Some Capabilities: SwitchToSSLAfterHandshake, ConnectWithDatabase, SupportsTransactions, LongColumnFlag, Speaks41ProtocolNew, SupportsCompression, Support41Auth
|   Status: Autocommit
|_  Salt: cGxI@DvF9+iR>}|wbcI%
5432/tcp open  postgresql  PostgreSQL DB 8.3.0 - 8.3.7
|_ssl-date: 2026-11-09T14:18:59+00:00; -26m07s from scanner time.
| ssl-cert: Subject: commonName=ubuntu804-base.localdomain/organizationName=OCOSA/stateOrProvinceName=There is no such thing outside US/countryName=XX
| Not valid before: 2010-03-17T14:07:45
|_Not valid after:  2010-04-16T14:07:45
5900/tcp open  vnc         VNC (protocol 3.3)
| vnc-info:
|   Protocol version: 3.3
|   Security types:
|_    VNC Authentication (2)
6000/tcp open  X11         (access denied)
```

Figure 3: *Nmap scan output, part 2 of 3: ports 80-6000, including MySQL and PostgreSQL service details.*

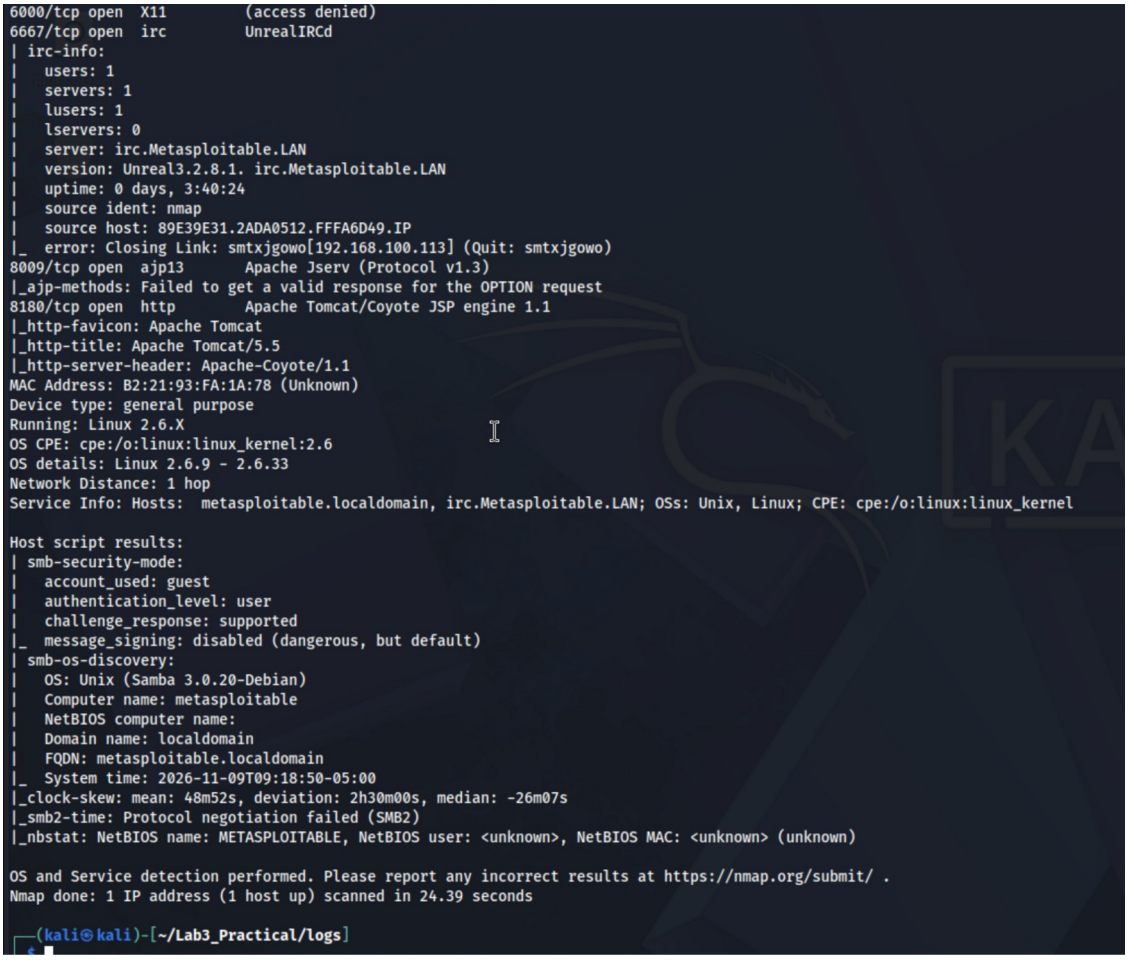


Figure 4: *Nmap scan output, part 3 of 3: remaining ports, OS fingerprint (Linux 2.6.9-2.6.33), and the SMB host script results showing message signing disabled.*

Interpretation

Three results stand out as critical-severity indicators even before any exploitation was attempted: Nmap's own service-fingerprint database labels the service on port 1524 as a “Metasploitable root shell”; the vsftpd banner on port 21 matches a publicly documented, intentionally backdoored release; and SMB message signing is reported as disabled, which weakens the protocol's integrity guarantees and lines up with the legacy Samba version exploited in Finding 4. This breadth of exposure — 23 open services, several unauthenticated, several running software with known CVEs — is far more consistent with a deliberately vulnerable training image than a production host, and it shaped the priorities for the manual testing phase that followed.

5. Automated Vulnerability Scanning (Greenbone GVM/OpenVAS)

Greenbone Vulnerability Management (GVM/OpenVAS) was installed on the Kali assessment host to provide an independent, automated check of the attack surface found above.

5.1 Installation and Verification

Initial setup hit a PostgreSQL collation-version mismatch on the template1 database, which blocked gvmd database initialization. This was fixed by refreshing the database's collation metadata, after which the gvmd database was created and the admin account provisioned. Re-running the setup checker confirmed a healthy installation: the scanner, manager and certificate chain all passed, and the local NVT (Network Vulnerability Test) library held 95,107 signatures.

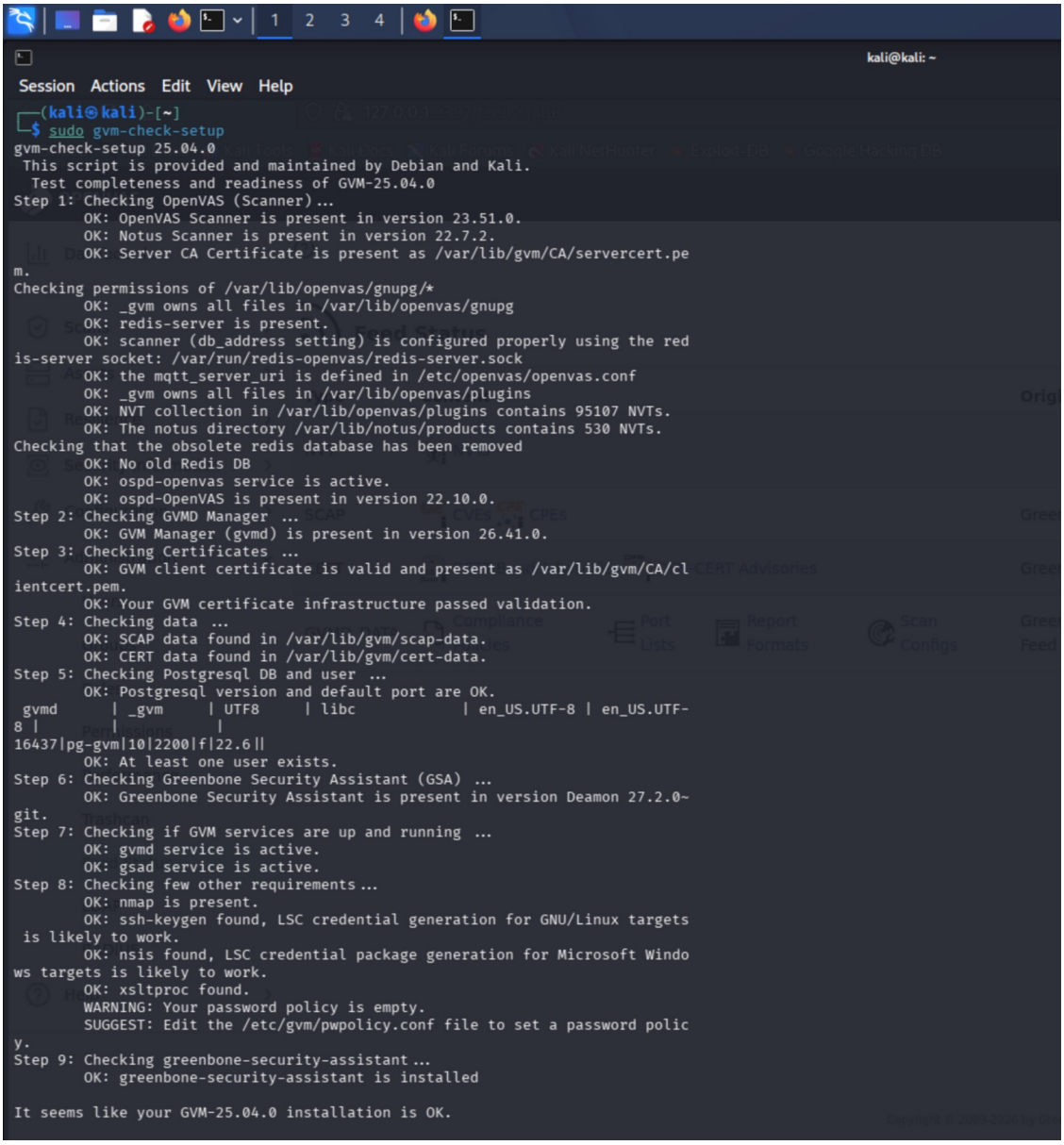


Figure 5: *gvm-check-setup confirming a healthy installation: scanner present, GVM Manager (gvmd) present, certificate chain valid, and 95,107 NVTs indexed.*

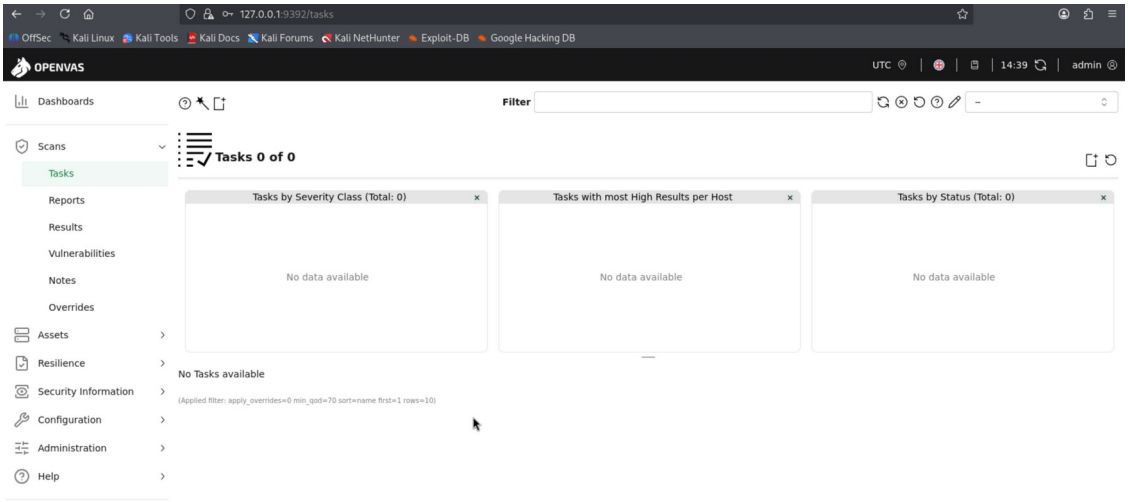


Figure 6: *Greenbone Security Assistant web console, reachable at https://127.0.0.1:9392 and signed in as the provisioned admin account. No scan task has been created yet at this point.*

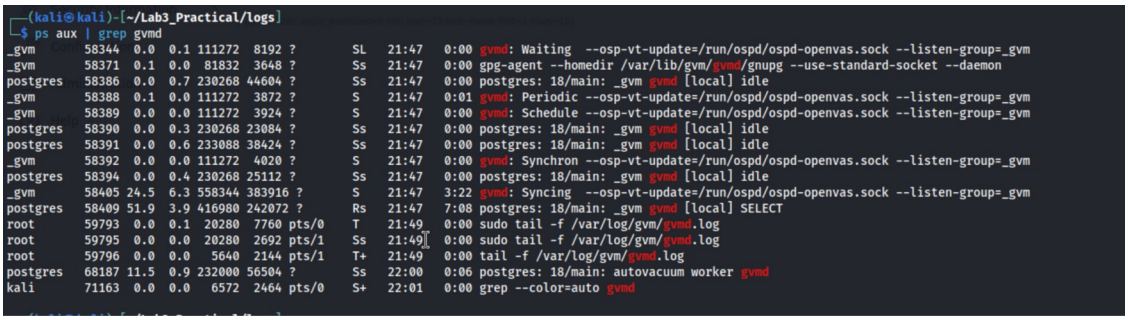


Figure 7: *Background process list confirming gvmd and PostgreSQL were actively processing vulnerability-feed data (COPY and sync operations) at the time of the check.*

5.2 Feed Synchronization Status

A GVM scan is only as good as the vulnerability data behind it, so the scan task was deliberately held back until feed synchronization progressed. Figure 8 shows the feed status earlier in the process: the NVT feed was still reporting a scanner-starting issue, and the SCAP, CERT and GVMD_DATA feeds were mid-update. A later check (visible in the background of Figure 12) shows the NVT feed had reached a Current status, while the other three feeds were still updating.

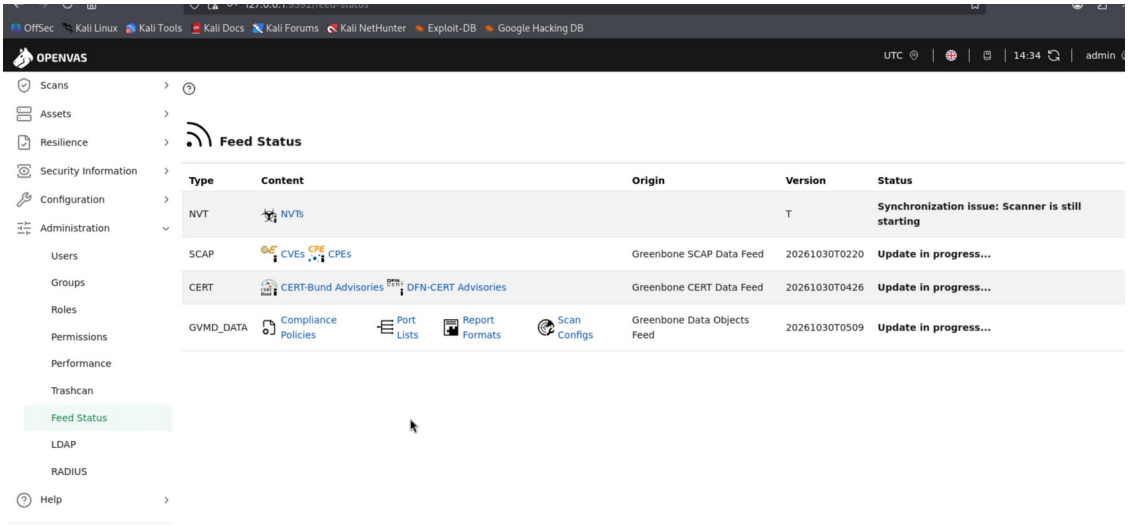


Figure 8: *GVM Feed Status page: the NVT feed reports a scanner-starting issue, and the SCAP, CERT and GVMD_DATA feeds are mid-update.*

Evidence note: no completed GVM scan task or report is included in the screenshots provided for this submission. The Key Metrics table in Section 1 reflects this honestly rather than quoting scan numbers that cannot be shown here. If a finished scan report becomes available, it should be added to this report and cross-checked against the four manually confirmed findings in Section 6.

6. Detailed Findings and Exploitation Proof

This section documents the four findings that were taken all the way to a working proof of concept, in a consistent format: affected asset, severity, weakness class, description, proof and impact, and evidence. Severity is scored independently with CVSS v3.1 base metrics.

ID	Finding	Port	Severity	CVSS 3.1
F-01	vsftpd 2.3.4 backdoor (CVE-2011-2523)	21/tcp	Critical	9.8
F-02	Default credentials with unrestricted sudo	22/tcp	High	8.1
F-03	Unauthenticated root shell listener	1524/tcp	Critical	9.8
F-04	Samba usermap_script RCE (CVE-2007-2447)	139/445/tcp	Critical	9.8

Finding 01: Backdoor Command Execution in vsftpd 2.3.4 (CVE-2011-2523)

Affected asset	192.168.100.114, port 21/tcp (vsftpd 2.3.4)
Severity	Critical — CVSS 3.1 base score 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Weakness class	CWE-78, Improper Neutralization of Special Elements used in an OS Command (OS command injection)
Metasploit module	exploit/unix/ftp/vsftpd_234_backdoor
Authentication required	None

In July 2011, the official vsftpd 2.3.4 source archive was compromised and quietly replaced with a backdoored copy. A client that supplies the characters “:)” inside the username during FTP login triggers the planted code, which opens an unauthenticated shell on TCP port 6200 of the target. The affected archive was available for a short time before the compromise was caught, and the backdoored binary is still present by design in the Metasploitable 2 training image used in this lab.

Proof of Concept

The corresponding Metasploit module was loaded and pointed at the target. The first attempt failed because the RHOST value had accidentally been left pointing at the assessor's own machine, and Metasploit correctly refused the connection (Figure 9). Setting RHOST to the real target address and re-running the exploit succeeded immediately: Metasploit's automatic check confirmed the vulnerable banner, triggered the backdoor, and a Meterpreter session opened (Figure 10). Session identity was then confirmed with getuid, sysinfo, and a dropped interactive shell running id, whoami, hostname, and uname -a — all independently confirming full root access with no authentication step of any kind (Figure 11).

```
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOST 192.168.100.114
exploit
# inside the resulting Meterpreter session:
getuid
sysinfo
shell
id
whoami
hostname
uname -a
```

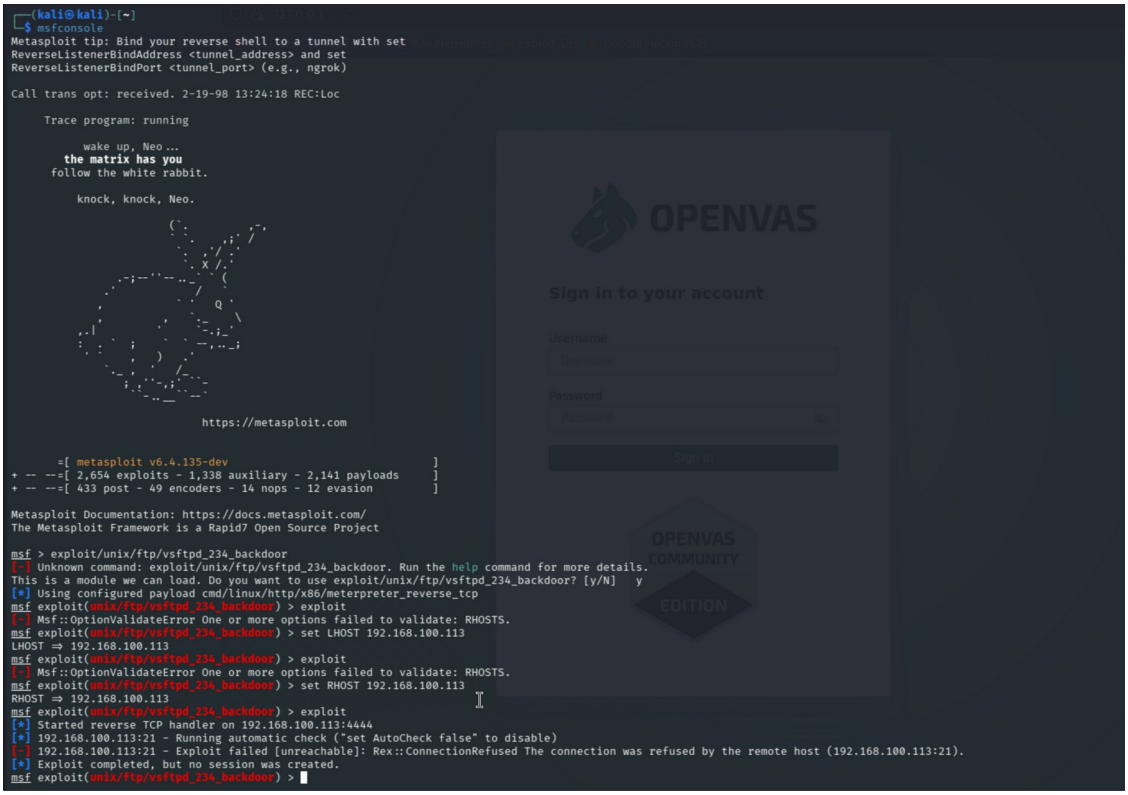


Figure 9: *First exploitation attempt: RHOST was mistakenly left at the assessor's own address, and Metasploit correctly refused the connection rather than failing silently.*

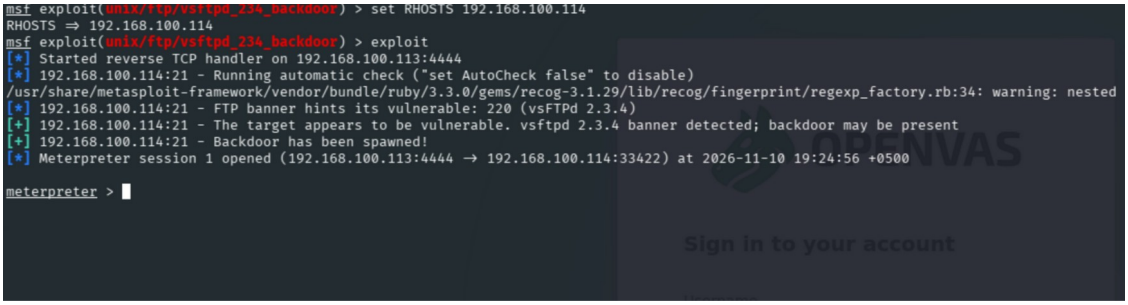


Figure 10: *Corrected attempt: RHOST set to the real target, automatic vulnerability check passes, and Meterpreter session 1 opens.*

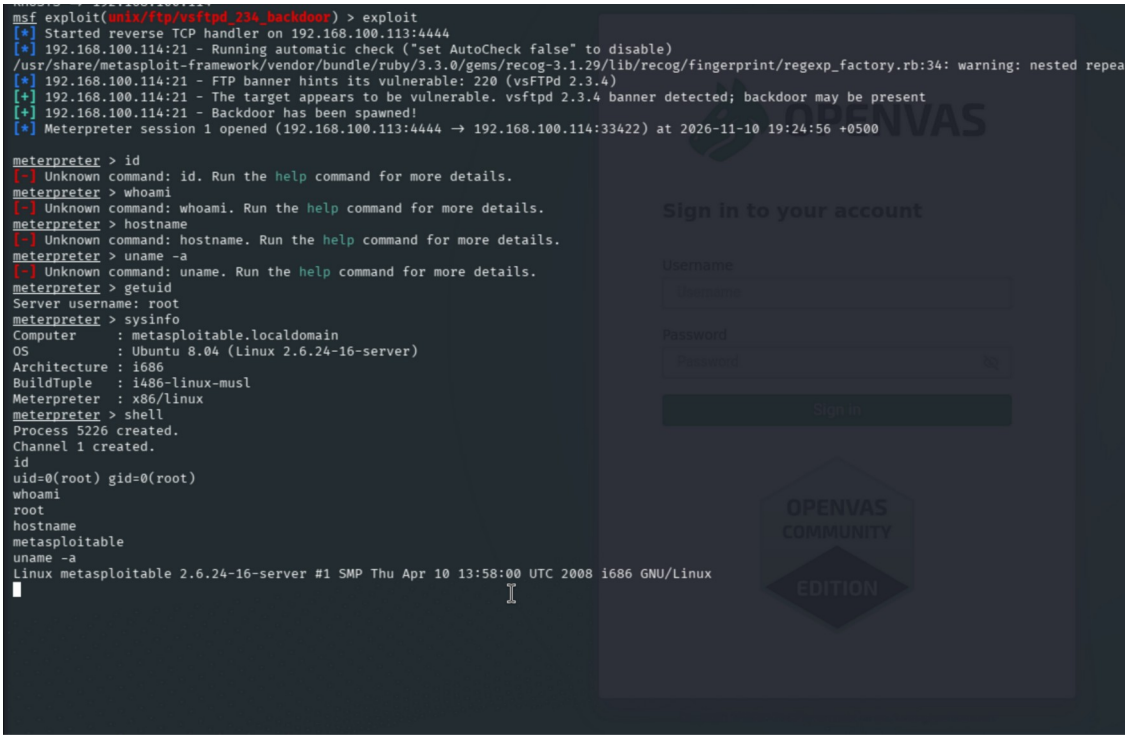


Figure 11: *Session verification: getuid reports "root", sysinfo confirms the target OS, and a dropped shell confirms uid=0(root) via id, whoami, hostname and uname -a.*

Business Impact

This path gives complete, unauthenticated compromise of the host in a single step. Anyone who can reach port 21 — with no credentials, no reconnaissance beyond a port scan, and no social engineering — gets root.

Finding 02: Default Credentials Leading to Unrestricted Sudo Root Access

Affected services	22/tcp (SSH); the same credential pair also works against FTP and MySQL on this host
Severity	High — CVSS 3.1 base score 8.1 (CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:H/I:H/A:H)
Weakness class	CWE-1392, Use of Default Credentials; CWE-250, Execution with Unnecessary Privileges
Credentials used	msfadmin : msfadmin (a documented default account on the Metasploitable 2 image)
Authentication required	Valid, but default and publicly documented, credentials

The account msfadmin logs in successfully over SSH using its well-known default password. Checking its sudo policy with sudo -l revealed an unrestricted entry, (ALL) ALL, meaning the account can run any command as any user, including root, with no privilege-escalation exploit required at all.

Proof of Concept

An SSH session was opened with the default credential pair. Once logged in, sudo -l confirmed the unrestricted (ALL) ALL grant, and running sudo su with the account's own password moved the session straight to root, confirmed by id returning uid=0(root) gid=0(root) groups=0(root).

```
ssh msfadmin@192.168.100.114
whoami
id
sudo -l
sudo su
id
```

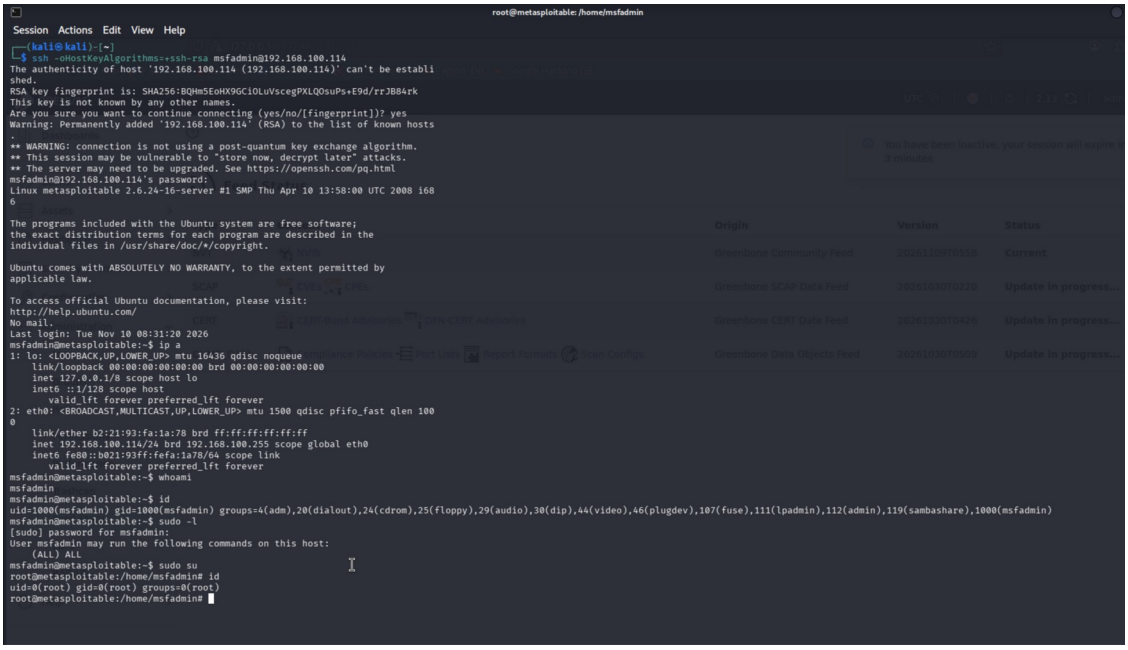


Figure 12: *SSH login as msfadmin with the default password, followed by whoami, id, sudo -l (showing the unrestricted (ALL) ALL grant), and sudo su escalating straight to uid=0(root).*

Business Impact

This finding shows that credential hygiene and privilege review matter just as much as patching. No software vulnerability was exploited here, only a documented default password and an overly permissive sudo rule — both configuration mistakes, and both fully preventable without a single software update.

Finding 03: Unauthenticated Root Shell Listener on Port 1524

Affected service	192.168.100.114, port 1524/tcp, identified by Nmap's own fingerprint database as a “Metasploitable root shell”
Severity	Critical — CVSS 3.1 base score 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Weakness class	CWE-287, Improper Authentication; CWE-1188, Initialization of a Resource with an Insecure Default

Tooling used	netcat (nc)
Authentication required	None

Port 1524 hosts a raw, unauthenticated shell attached directly to /bin/sh, running as root. This is a leftover debugging or backdoor listener built into the training image, with no login prompt, credential check, or handshake of any kind in front of it.

Proof of Concept

A plain TCP connection to port 1524 was opened with netcat. The connection dropped straight into an interactive shell; both id and whoami confirmed the shell was already running as root, with no authentication step having occurred at any point.

```
nc 192.168.100.114 1524
id
whoami
```

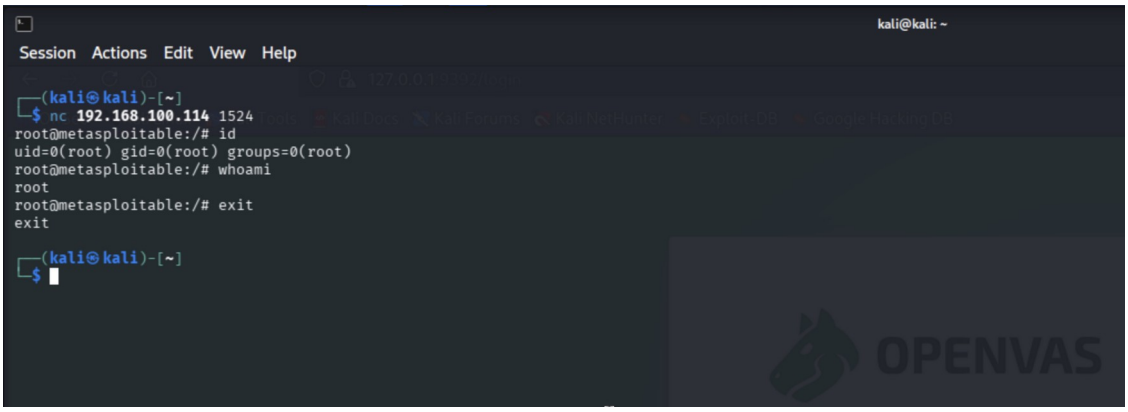


Figure 13: *A plain netcat connection to port 1524 lands directly in an interactive root shell; id and whoami confirm uid=0(root) with no authentication performed.*

Business Impact

This is the simplest and most severe finding in the engagement: no exploit framework, no payload, and no vulnerability research were needed, only a standard TCP client. Any port scan that notices 1524 open has effectively found a full root compromise.

Finding 04: Samba 3.0.20 usermap_script Remote Command Execution (CVE-2007-2447)

Affected service	192.168.100.114, ports 139 and 445/tcp (Samba smbd 3.0.20-Debian)
Severity	Critical — CVSS 3.1 base score 9.8 (CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H)
Weakness class	CWE-78, OS Command Injection
Metasploit module	exploit/multi/samba/usermap_script
Authentication required	None

Samba versions from 3.0.20 to 3.0.25rc3 support a “username map script” setting that passes an attacker-supplied username straight to a shell without filtering shell metacharacters. By embedding shell metacharacters in the username field of an authentication request, an

unauthenticated remote attacker can run arbitrary commands with the privileges of the Samba daemon — root, by default on this image.

Proof of Concept

The Metasploit usermap_script module was pointed at the target with its default reverse-shell payload and run. A command-shell session opened immediately; id and whoami confirmed root-level command execution with no authentication performed, in a separate Metasploit console session from Finding 01.

```
use exploit/multi/samba/usermap_script
set RHOST 192.168.100.114
exploit
id
whoami
hostname
```

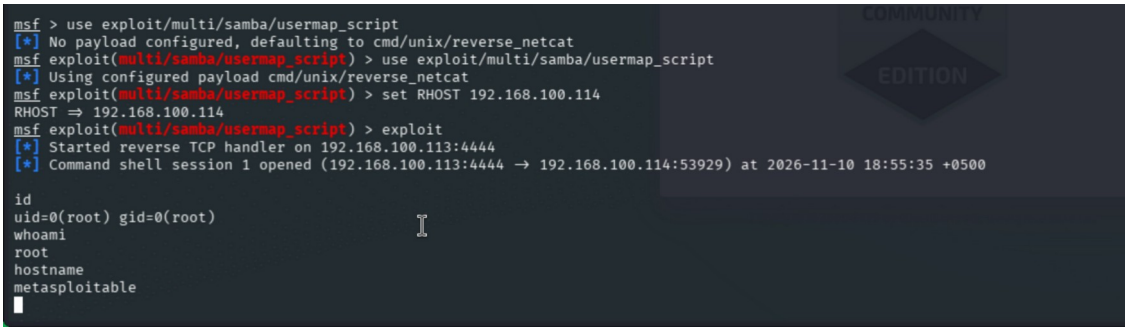


Figure 14: *Metasploit's usermap_script module opening a command-shell session over port 445; id and whoami confirm uid=0(root).*

Business Impact

A second, fully independent unauthenticated path to root confirms that this host's exposure is not down to one misconfigured service: at least two unrelated services (vsftpd and smbd) each independently hand over full root access.

7. Post-Exploitation Demonstration

Getting a shell is the start of a penetration test, not the end of it. To show real impact rather than a theoretical finding, root access from Finding 01 was used to read the protected system credential file, /etc/shadow.

```
head -n 5 /etc/shadow
```

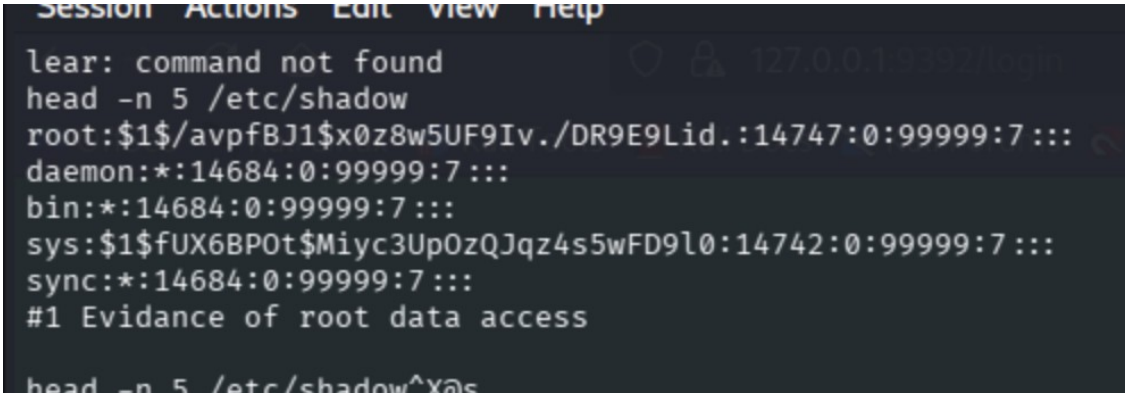


Figure 15: *The first five lines of /etc/shadow, read using the root access obtained in Finding 01. Hash values are visible in the original screenshot and are not transcribed here.*

Evidence note: this screenshot confirms that root access allows the full local password-hash database to be read for offline cracking. The engagement notes also describe staging a temporary, reversible persistence entry and removing it immediately afterwards; no screenshot of that step is included in this evidence set, so it is mentioned here for completeness but is not independently confirmed by a figure.

Interpretation

This step turns the four technical findings in Section 6 into a plain business-risk statement: an attacker reaching this host does not just get “a shell”. They get the ability to harvest every credential on the system, and potentially to set up access that survives a reboot or a partial fix, all without necessarily leaving an obvious trace if logging is not actively monitored.

8. Conclusion and Recommendations

Four independent, low-barrier paths to full root compromise were confirmed with working proof-of-concept exploits: a backdoored FTP service, a raw root shell left listening on a spare port, a command-injection flaw in the file-sharing service, and a documented default password paired with an unrestricted sudo rule. Three of the four require no authentication at all. This level of exposure is expected for Metasploitable 2, since it is built to be vulnerable for training purposes, but the same classes of weakness — outdated software, default credentials, and unnecessary exposed services — show up regularly on real networks too.

Priority Recommendations

Priority	Action
1	Remove or replace the backdoored vsftpd 2.3.4 build with a verified, current version.
2	Disable the raw root shell service on port 1524, and remove whatever starts it.
3	Patch or disable Samba's username map script feature (upgrade beyond 3.0.25rc3).
4	Change the msfadmin password, and replace the unrestricted (ALL) ALL sudo rule with least-privilege access.
5	Enable SMB message signing, disable SSLv2 and weak ciphers on SMTP, and replace the expired certificate.
6	Close or firewall services that are not needed (telnet, rexec, rlogin, X11, unauthenticated VNC, and similar).
7	Finish GVM feed synchronization and run a complete authenticated scan to confirm or extend these findings.

Work Completed

- Network isolation checked and the host-only lab boundary confirmed before any intrusive activity.
- Full TCP service, version and OS enumeration completed against the target (23 open ports mapped).
- GVM/OpenVAS installed and verified (all setup checks passed, 95,107 NVTs indexed); feed synchronization was in progress at the time of writing.
- Four findings independently confirmed with full root-level proof of concept.
- Post-exploitation impact demonstrated for sensitive-data exposure.

- This report drafted and finalized.

Evidence and Repository

All raw command output, full-resolution screenshots, and the Nmap scan file referenced throughout this report are kept in the course repository:

https://github.com/MuhammadLateef/digital-forensic-cyber-security-pseb-bootcamp/tree/main/s07-report